

Cyber Threat Intelligence

Executive Briefing

Report Date: July 02, 2026

Generated: 2026-07-02 23:57 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
3	10	6	1	20

2. Executive Summary

This Cyber Threat Intelligence briefing for July 02, 2026, details the assessment of 20 total vulnerabilities, classified as 3 Critical, 10 High, 6 Medium, and 1 Low severity. The current organizational risk posture is evaluated as 'High,' driven primarily by exposure to session management and isolation bypass flaws. The most critical threat, CVE-2026-52830 (Path Traversal in fast-mcp-telegram), is prioritized due to the potential for unauthorized filesystem access via session manipulation, representing a direct threat to core infrastructure integrity. It is the formal recommendation of the Security Office that the organization transition to an 'Immediate Remediation' posture, prioritizing the deployment of patches for all Critical and High findings within the next 48 hours. Board-level oversight is requested to ensure rapid resource allocation for these essential security mitigations.

3. Critical Action List

- Execute immediate patch deployment and service restart for CVE-2026-52830 within 24 hours to prevent unauthorized path traversal.
- Implement network segmentation and access control overrides for Steeltoe management ports to mitigate CVE-2026-50194 by the close of business, July 03.
- Apply vendor-issued patches or disable the affected HTTP-Artifact module for CVE-2026-49283 within 48 hours to prevent TLS validator confusion.
- Sanitize environment configurations and rotate all database credentials exposed by CVE-2026-50200 within 48 hours.
- Update the Eureka discovery client to enforce strict input validation for the DataCenterInfo.Name field to address CVE-2026-50196 within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-52830	Path Traversal in fast-mcp-telegr...	9.4	Critical	85/100	CWE-22
CVE-2026-50194	Management-Port Isolation Bypass ...	9.8	Critical	84/100	CWE-288
CVE-2026-50200	Database Credential Leak via Env ...	7.5	High	78/100	CWE-200
CVE-2026-50196	Eureka Registry Poisoning in Stee...	8.2	High	78/100	CWE-20
CVE-2026-49283	TLS Validator Confusion in Simple...	9.1	Critical	78/100	CWE-295
CVE-2026-9809	Stored XSS in Mautic Projects Com...	7.6	High	78/100	CWE-79
CVE-2026-9808	Authorization Bypass in Mautic AP...	8.2	High	74/100	CWE-863
CVE-2026-52817	Privilege Escalation in Linuxfabr...	7.8	High	70/100	CWE-88
CVE-2026-50201	Insecure Actuator Permissions in ...	6.5	Medium	69/100	CWE-269
CVE-2026-9811	Stored XSS in Mautic Project Sele...	5.4	Medium	69/100	CWE-79
CVE-2026-49289	Denial of Service in SimpleSAMLphp	7.5	High	68/100	CWE-400
CVE-2026-52829	Mempool Misbehavior in Zebra Addr...	7.5	High	68/100	CWE-617
CVE-2026-52746	Resource Exhaustion in jsonata	7.5	High	68/100	CWE-1333
CVE-2026-50281	Mass Assignment Overwrite in Craf...	7.6	High	66/100	CWE-915
CVE-2026-50282	Unauthorized Deletion in Craft CMS	8.1	High	64/100	CWE-862
CVE-2026-50202	JWKS Cache Invalidation Failure i...	5.6	Medium	63/100	CWE-668
CVE-2026-52733	On-disk Corruption in zebra Subt...	6.5	Medium	59/100	CWE-459
CVE-2026-50267	Insecure TLS Key Storage in Steel...	4.7	Medium	52/100	CWE-312
CVE-2026-52734	Unbounded Memory Leak in zebra P...	5.3	Medium	48/100	CWE-401
CVE-2026-50268	Weak RSA Padding in Steeltree OAEF	3.7	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-52830

Finding: Path Traversal in fast-mcp-telegram

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

MITRE ATT&CK: T1592, T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The fast-mcp-telegram component is vulnerable to a path traversal flaw within its session management logic. This issue arises from improper validation of file path inputs, allowing attackers to bypass reserved Telegram session protections. The flaw leads to unauthorized access to sensitive session files, requiring network-level access for exploitation.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the Telegram session storage endpoint. The attacker submits a specially crafted path string containing relative path directory traversal sequences to the service. The backend fails to sanitize this input, allowing access to session files outside the intended directory. This results in the potential hijacking of active Telegram sessions controlled by the application.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52830>

CVE-2026-50194

Finding: Management-Port Isolation Bypass in Steeltoe

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 84/100 | CWE: CWE-288

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Steeltoe fails to enforce strict management-port isolation, allowing attackers to bypass access controls using a spoofed Host header. The root cause is a trust-based validation process that relies on user-supplied request headers rather than network-level origin verification. This vulnerability permits unauthorized access to sensitive administrative ports, leading to potential full control of the application environment.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the application's management port while specifying a spoofed Host header in the request. The Steeltoe framework incorrectly identifies the request as coming from a trusted local network context. The server allows the request to reach administrative handlers normally restricted to local access. This results in the attacker gaining unauthorized access to administrative functionality and sensitive system internals.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50194>

CVE-2026-50200

Finding: Database Credential Leak via Env Sanitizer

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-200

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe environment sanitizer fails to filter embedded connection strings, resulting in the leakage of cleartext database credentials. This vulnerability stems from incomplete regex pattern matching within the sanitization logic for environment property sources. Unauthenticated attackers accessing management endpoints can gain access to sensitive credentials, compromising database confidentiality and integrity.

Proof of Concept (PoC):

An unauthenticated remote attacker performs a GET request to the exposed /env management endpoint. The server responds with the current runtime properties, including unmasked database connection strings. The attacker parses these strings to identify plaintext credentials. This results in the successful unauthorized access and compromise of the backend database.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50200>

CVE-2026-50196

Finding: Eureka Registry Poisoning in Steeltoe

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 78/100 | CWE: CWE-20

MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Steeltoe Eureka discovery client improperly handles the DataCenterInfo.Name field, allowing unrecognized inputs to corrupt the entire service registry. This occurs because the library lacks sufficient input validation when parsing discovery metadata from external services. Remote attackers can inject malicious data to cause widespread service unavailability within the discovery ecosystem.

Proof of Concept (PoC):

An attacker registers a malicious service instance with the Eureka registry using a specially crafted DataCenterInfo.Name attribute. The Steeltoe-based discovery client fetches this registry update and fails to process the invalid metadata. This corruption causes the registry fetch pipeline to fail for all dependent applications. This results in a massive service discovery outage across the microservices architecture.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50196>

CVE-2026-49283

Finding: TLS Validator Confusion in SimpleSAMLphp

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 78/100 | CWE: CWE-295

MITRE ATT&CK: T1557, T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

SimpleSAMLphp suffers from a TLS validator confusion vulnerability in its HTTP-Artifact implementation that allows cross-IdP authentication bypass. This flaw is caused by insufficient validation of identity provider metadata during the artifact resolution process, where the TLS context of a secondary connection can be incorrectly attributed to a primary request. This enables an attacker to impersonate legitimate users by spoofing SAML responses.

Proof of Concept (PoC):

An unauthenticated attacker sets up a malicious IdP and initiates an authentication handshake with the target service. The attacker triggers a request that causes the SimpleSAMLphp HTTP-Artifact module to resolve against the malicious IdP's metadata instead of the intended IdP. The application improperly trusts the assertions returned by the attacker's IdP because the TLS validation context was confused. This results in the attacker successfully logging in as any user in the system.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49283>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49283>

CVE-2026-9809

Finding: Stored XSS in Mautic Projects Component

CVSS v3.1 Score: 7.6 | Severity: High | Urgency Score: 78/100 | CWE: CWE-79

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

Mautic contains a stored XSS vulnerability within the projects component due to improper rendering of user-provided content. This flaw arises from insufficient sanitization of input data before it is persisted and subsequently reflected in the admin dashboard. An attacker can use this to hijack administrator sessions or manipulate the application state.

Proof of Concept (PoC):

An authenticated attacker submits a payload within a Project description field that contains embedded script tags. The backend saves the description to the database without sanitization. An administrator views the Projects list, triggering the rendering of the payload in their browser. This results in the script executing with the administrator's privileges, allowing for full unauthorized management of the system.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-9809>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-9809>

CVE-2026-9808

Finding: Authorization Bypass in Mautic API v2

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-863

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Mautic API v2 endpoints are subject to an authorization bypass vulnerability, allowing unauthenticated or improperly authorized requests to access restricted data. The issue lies in the validation layer, which incorrectly handles token-based requests for certain legacy v2 API routes. This allows remote attackers to access, modify, or delete sensitive user and marketing information.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to a sensitive Mautic API v2 endpoint without providing a valid authentication token. The application service fails to perform the required access control check for that specific v2 route. The API processes the request and returns protected administrative data to the attacker. This results in the unauthorized disclosure of private system data and marketing strategy details.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-9808>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-9808>

CVE-2026-52817

Finding: Privilege Escalation in Linuxfabrik Plugins

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 70/100 | CWE: CWE-88

MITRE ATT&CK: T1068, T1548

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Linuxfabrik monitoring plugins for /usr/bin/apt-get are vulnerable to a command injection flaw that permits privilege escalation via crafted arguments in sudoers configurations. This is caused by the plugin passing user-controlled arguments to a command execution shell without proper sanitization or parameterization. If successful, this permits a local user to execute arbitrary commands with root privileges.

Proof of Concept (PoC):

A local user with low-privileged access identifies the monitoring plugin execution path within the sudoers configuration. The attacker executes the script by passing malicious shell operators and flags as arguments to the plugin. The plugin fails to validate these inputs and executes the malicious arguments with elevated root privileges. This results in full

system control and complete compromise of the local machine.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52817>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52817>

CVE-2026-50201

Finding: Insecure Actuator Permissions in Steeltoe

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-269

MITRE ATT&CK: T1082, T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe exposes sensitive management actuators, such as heapdump and environment endpoints, with insufficient permission requirements. The root cause is an overly permissive configuration default for administrative handlers. An attacker can exploit this to extract sensitive runtime configuration and internal memory states, resulting in a loss of confidentiality.

Proof of Concept (PoC):

A low-privileged authenticated user makes a GET request to the /actuator/heapdump endpoint. The system processes the request and serves the full memory dump without validating administrative privileges. The attacker parses the response to extract sensitive keys and environment variables. This results in the full exposure of internal configuration data and system secrets.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50201>

CVE-2026-9811

Finding: Stored XSS in Mautic Project Selector

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-79

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Mautic is vulnerable to a stored cross-site scripting (XSS) attack within the project option selector component. The vulnerability occurs because user-supplied project names are stored in the database and rendered back to the dashboard without appropriate sanitization. An authenticated attacker can store malicious scripts that execute in the

context of other users' browsers.

Proof of Concept (PoC):

An authenticated user creates a new project and sets the project title to a malicious JavaScript payload. Mautic saves this string to the application database. Another user navigates to the project selection menu where the title is rendered into the DOM without escaping. This results in the execution of the attacker's script in the victim's session, potentially leading to session theft or unauthorized actions.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-9811>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-9811>

CVE-2026-49289

Finding: Denial of Service in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a denial-of-service attack due to improper processing of XML payloads in the XPath Transform component. The issue originates from the lack of constraints on XML parsing, leading to resource exhaustion when processing maliciously nested XPath queries. This vulnerability allows an unauthenticated remote attacker to crash the authentication service by submitting a specifically crafted XML document.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a POST request containing a deeply nested XPath expression within an XML-based authentication artifact. The SimpleSAMLphp parser consumes excessive CPU and memory resources while recursively traversing the malicious XML structure. The application hangs, becoming unresponsive to all legitimate authentication requests. This results in a temporary but total denial of service for the Identity Provider (IdP) service.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49289>

CVE-2026-52829

Finding: Mempool Misbehavior in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None

Integrity Impact

None

Availability Impact

High

Description:

The Zebra Address Book is subject to an instability issue resulting from improper handling of IPv4-mapped addresses within the mempool management pipeline. This error originates in the memory allocation tracking logic which fails to account for memory alignment requirements when interacting with specific address types. This results in an abrupt termination of the process, potentially causing a denial of service.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an address lookup request to the Zebra address book service containing a specially formatted IPv4-mapped address. The service attempts to map this address into its internal memory pool, triggering a consistency check failure during memory allocation. The application process reaches a 'panic' state and terminates immediately. This results in a complete denial of service for all users of the address book.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52829>

CVE-2026-52746**Finding: Resource Exhaustion in jsonata**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-1333

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The jsonata library is vulnerable to resource exhaustion when processing malicious inputs to the "\$toMillis" function. This occurs due to inefficient recursion within the regex-based time parsing logic, which allows for exponential execution time on carefully crafted input strings. Remote attackers can trigger this condition, leading to denial of service for any application utilizing the library.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a payload to a JSON-processing service that includes a deeply complex date-time string passed to the "\$toMillis" function. The engine attempts to parse this string using a vulnerable regular expression that triggers catastrophic backtracking. The service process consumes 100% CPU, freezing the application and becoming unresponsive. This results in a functional denial of service against the backend application.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52746>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52746>

CVE-2026-50281**Finding: Mass Assignment Overwrite in Craft CMS**

CVSS v3.1 Score: 7.6 | Severity: High | Urgency Score: 66/100 | CWE: CWE-915

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

Craft CMS is susceptible to mass assignment vulnerabilities, specifically allowing the modification of element IDs during bulk duplication operations. This vulnerability originates from an insecure implementation of the newAttributes processing logic which fails to blacklist sensitive properties. An attacker can overwrite existing records by injecting existing identifiers in the request payload.

Proof of Concept (PoC):

An authenticated user with limited permissions initiates a bulk duplication request using the Craft CMS interface. The user injects the ID of an existing, high-privilege record into the 'id' field within the 'newAttributes' JSON structure. The CMS processes the request and maps this value directly to the object model without sanitization. This results in the unintended modification and corruption of existing data records by the user.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50281>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50281>**CVE-2026-50282****Finding: Unauthorized Deletion in Craft CMS****CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-862**

MITRE ATT&CK: T1499, T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Craft CMS allows authenticated users to trigger unauthorized deletion of destination folders during forced move operations. This arises due to a failure in the permission enforcement mechanism when handling recursive filesystem actions. An attacker with specific low-level content management access can thereby destroy system-critical directories.

Proof of Concept (PoC):

An authenticated user with low privileges identifies the API endpoint used for moving assets. The user constructs a move command targeting a protected system directory instead of an asset folder. The backend service processes the request without validating that the user has permission to modify the target directory. This results in the recursive deletion of files within that destination, causing potential data loss or site failure.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50282>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50282>

CVE-2026-50202

Finding: JWKS Cache Invalidation Failure in Steeltoe

CVSS v3.1 Score: 5.6 | Severity: Medium | Urgency Score: 63/100 | CWE: CWE-668

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

The Steeltoe framework maintains a static JWKS cache that is incorrectly shared across authentication schemes and never invalidated. This behavior is caused by a global, singleton-based caching implementation that lacks context-aware scoping or expiration logic. Attackers can leverage this to persist revoked keys, potentially facilitating authorization bypass attacks against valid system components.

Proof of Concept (PoC):

An attacker monitors an authentication system integrated with the Steeltoe framework. The attacker detects that a previously revoked signing key remains functional within the application due to the static nature of the JWKS cache. By using the revoked key to sign authentication requests, the attacker continues to successfully authenticate. This results in the compromise of access control enforcement for an indeterminate period.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50202>

CVE-2026-52733

Finding: On-disk Corruption in zebra Subtree Roots

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-459

MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The zebra blockchain client is susceptible to persistent on-disk corruption of Sapling and Orchard subtree roots following a chain fork event triggered via pop_tip. This stems from a lack of atomicity in the rollback operations performed by the storage layer during reorganization. Consequently, subsequent node operations may rely on inconsistent ledger states, compromising data integrity.

Proof of Concept (PoC):

A network actor triggers a series of chain reorganization events by submitting conflicting block data to the zebra node. The service processes these reorganizations using the flawed pop_tip logic, causing the on-disk subtree roots for

Orchard and Sapling to become corrupted. Subsequent transaction verifications fail due to this inconsistency. This results in a loss of ledger accuracy and potential permanent failure of the node to validate the canonical chain.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52733>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52733>

CVE-2026-50267

Finding: Insecure TLS Key Storage in Steeltoe

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 52/100 | CWE: CWE-312

MITRE ATT&CK: T1552, T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe fails to securely manage TLS private keys by writing them to the /tmp directory with world-readable permissions and neglecting to perform deletion. This occurs due to inadequate cleanup routines and improper file permission settings during the initialization phase. Local users on the system can leverage this vulnerability to gain unauthorized access to sensitive cryptographic keys.

Proof of Concept (PoC):

A local attacker with low-privilege access scans the /tmp directory on the server during the application's lifecycle. The attacker identifies private key files that were improperly created by the Steeltoe framework and never purged from the disk. By reading these files directly, the attacker bypasses standard access controls. This results in the full exposure of private keys that can be used to decrypt secure communications or impersonate the service.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50267>

CVE-2026-52734

Finding: Unbounded Memory Leak in zebra Pipeline

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-401

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The zebra service suffers from an unbounded memory leak in its mempool download pipeline caused by improper handling of cancelled handles during timeouts. This occurs because the internal cleanup routine fails to release

resources associated with cancelled download jobs. Over time, this leads to excessive memory consumption, which may result in process termination.

Proof of Concept (PoC):

An unauthenticated remote attacker repeatedly initiates mempool download requests and cancels them shortly after in a rapid loop. The zebra service spawns internal handles for these requests but fails to properly garbage-collect the cancelled handle state. Memory usage on the node increases linearly until the system exhausts available resources. This results in severe performance degradation and eventual process crash.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52734>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52734>

CVE-2026-50268

Finding: Weak RSA Padding in Steeltree OAEP

CVSS v3.1 Score: 3.7 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Steeltree library incorrectly selects PKCS#1 v1.5 padding during cryptographic operations even when OAEP is explicitly configured. This configuration error stems from a silent fallback mechanism in the underlying provider instantiation. This flaw compromises the confidentiality of encrypted communications, requiring an attacker to intercept the ciphertexts.

Proof of Concept (PoC):

An attacker with network monitoring capabilities intercepts encrypted traffic using the Steeltree framework. The attacker captures ciphertexts that the library incorrectly processes using PKCS#1 v1.5 padding instead of the secure OAEP standard. The server attempts to decrypt the message using the weaker legacy padding scheme. This results in an increased risk of side-channel attacks that can recover partial plaintext.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official

databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>